

V0088

Advanced Information Security

高级信息安全

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,
Ajou University, Korea

现实安全协议

- SSH——相对简单且实用的协议
- SSL —— Web上的实用安全
- IPSec —— IP层安全
- **Kerberos ——对称密钥，单点登录**
- **WEP——安全协议的“瑞士奶酪”**
- **GSM——移动电话（不）安全**

Kerberos安全协议

- 在希腊神话中，Kerberos是一只三头犬，守护着冥界的入口，。
 - 职责是只让亡灵进入，禁止其离开；禁止活人闯入。
 - 在安全领域，Kerberos 是一种基于**对称密钥加密**的身份验证协议。
 - 起源于麻省理工学院
 - 基于 Needham-Schroeder 方案 
 - 依赖于**可信第三方**
(TTP: Trusted Third Party)
- 对称密钥协议（1978年）→现代认证协议的理论基础
非对称密钥协议→存在漏洞→Lowe 修正→ Needham-Schroeder-Lowe协议

Kerberos 的动机

- 使用**公钥**进行身份验证
 - N 个用户 $\Rightarrow$ N对密钥 信任管理问题：需要公约基础设施/分发信任机构
- 使用**对称密钥**进行身份验证
 - N 个用户：每对用户共享一个对称密钥，共需要 $N(N-1)/2 \approx N^2$ 个密钥
- **对称密钥在小规模可以，大规模密钥不可扩展（分发困难，管理复杂）**
- Kerberos 基于对称密钥，但仅需N 个密钥即可满足N 个用户的需求。
 - 安全取决于战术、技术和程序 (**TTP/KDC**)。
 - + 无需公钥基础设施 (PKI)

Kerberos KDC

- Kerberos **密钥分发中心** (**KDC**: Key Distribution Center)
 - KDC 充当 TTP 的角色。
 - TTP系统是可信的，因此绝不能被攻破。
- 与 Alice共享对称密钥 K_A ，与 Bob共享密钥 K_B ，与 Carol共享密钥 K_C ，等等。
- 还有一把名为 K_{KDC} 的主密钥，只有KDC知道。
- KDC允许保持上下文无关，排除拒绝服务攻击的可能性。
- KDC 支持身份验证和会话密钥
 - 用于保密性和完整性的会话密钥
- 实际上，加密算法是**DES**。

Kerberos Tickets (票据)

- KDC 签发包含访问网络资源所需信息的**服务票据**
- KDC发放用于承认票据的**取票凭证 (TGT)**，用来允许访问网络资源。
- 每个TGT包含
 - 会话密钥
 - 用户 ID
 - 终止时间
- 每个TGT都使用 K_{KDC} 加密。
 - 因此，TGT只能由KDC读取。

登录 → 得到 TGT



用 TGT → 换 服务票据

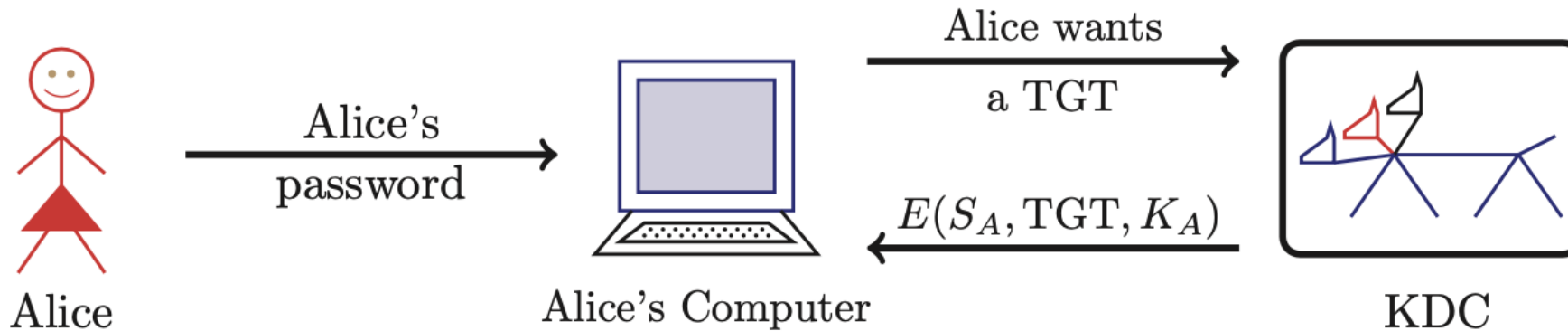


用 服务票据 → 访问服务

Kerberos注册

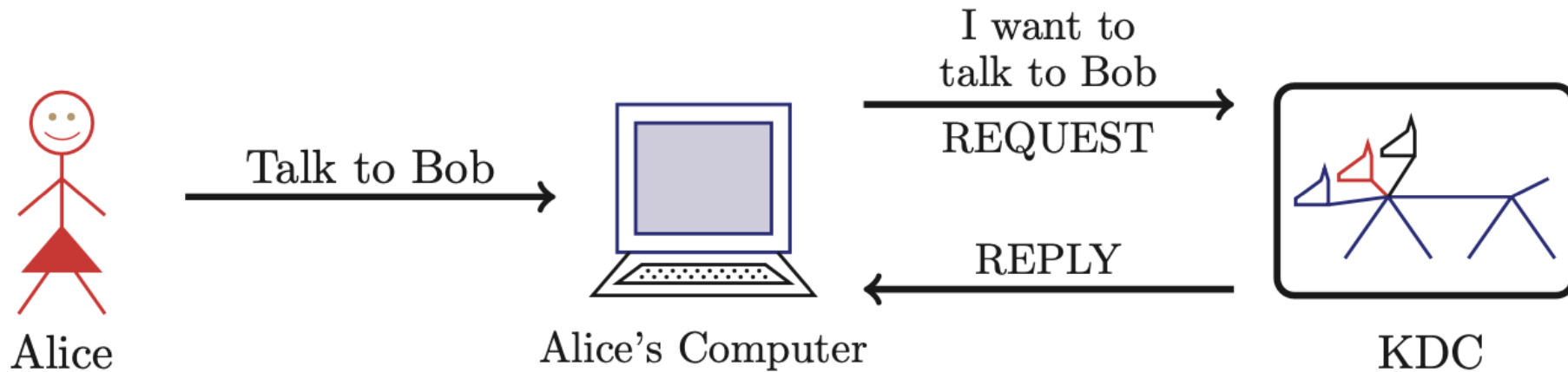
- Alice输入密码
- 然后, Alice的电脑执行以下操作:
 - 从 Alice 的密码中导出 K_A
 - 使用 K_A 从 KDC获取Alice 的**TGT**。
- 然后, Alice 使用她的TGT (凭证) 安全地访问网络资源。
- **优点:** 安全对Alice来说是透明的。
- **缺点:** KDC**必须** 安全可靠——值得信赖!

Kerberos注册



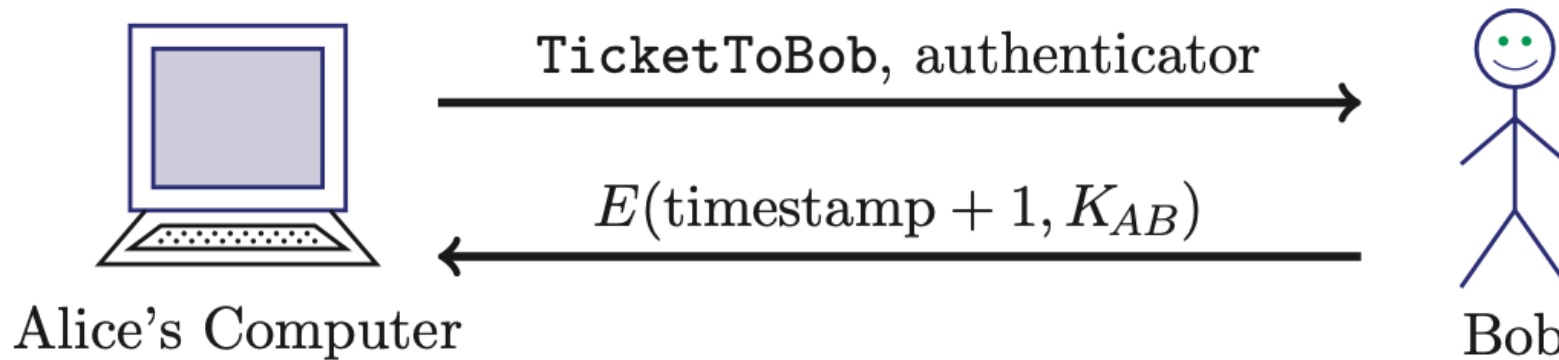
- 密钥 $K_A = h(\text{Alice 的密码})$
- KDC 创建会话密钥 S_A
- Alice 的电脑解密了 S_A 和TGT
 - 然后它忘记了 K_A
- $TGT = E(\text{"Alice"}, S_A, K_{KDC}) = E(K_{KDC}, [\text{Alice}, S_A, \text{Timestamp}, \text{Lifetime}])$

Alice请求“前往Bob的车票”



- 请求 = (TGT, 验证器)
 - 验证器 = $E(\text{时间戳}, S_A)$ ➡ 避免重放攻击
- 回复 = $E(\text{"Bob"}, K_{AB}, \text{给 Bob 的票据}, S_A)$
 - 给 Bob 的票 = $E(\text{"Alice"}, K_{AB}, K_B)$
- 从TGT获取 S_A 以验证时间戳

Alice用票去Bob



- 给 Bob 的票 = $E(\text{"Alice"}, K_{AB}, K_B)$
- 验证器 = $E(\text{时间戳}, K_{AB})$
- Bob 解密“给 Bob 的票”以获得 K_{AB} ，然后他用 K_{AB} 来验证时间戳。

Kerberos

- 用于身份验证的**密钥** S_A
 - 为了保密性/完整性
- 用于身份验证和重放保护的**时间戳**
- 请记住，时间戳.....
 - 减少消息数量——就像事先知道的随机数一样
 - 但是，“时间”是一个至关重要的安全参数。
- 在Kerberos中，时钟偏差被典型的设置为5分钟。

关于 Kerberos 的问题

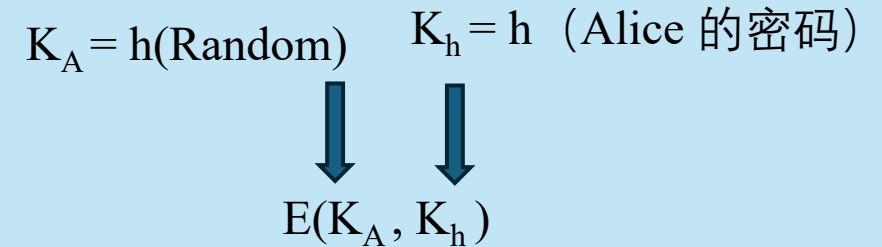
- 当 Alice 登录时, KDC 发送 $E(S_A, TGT, K_A)$ 在这里 $TGT = E(\text{"Alice"}, S_A, K_{KDC})$
 - 问: 为什么 TGT 使用 K_A 加密?
 - A: 这样只有 Alice 可以解密, 后期在 KDC 请求票据时不用再发送密码。
- 在 Alice 通过 Kerberos 身份验证登录 Bob 时, 为什么 Alice 可以保持匿名?
 - 只需要提供服务票据, 不再需要账户密码
- 为什么“给 Bob 的票”会发送给 Alice?
 - Alice 是通信发起人, 自己携带票据去访问。
- 为什么 KDC 不直接寄给 Bob?
 - KDC 不知道 Bob 在哪, Kerberos 目标: 上下文无关, 不自己建立连接

Kerberos替代方案

- 可以让Alice的电脑记住密码，并用它来进行身份验证。
 - 那么就不需要KDC了
 - 但密码很难保护。
 - 此外，它不具备可扩展性。
 - 可以让 KDC 记住会话密钥，而不是将其放在TGT中。
 - 那么就不需要TGT了。
 - 但**无状态**KDC 是 Kerberos 的一个主要特征。
- KDC/TGS 不需要记住任何登录状态
收到TGT，解密后知道用户以及会话密钥

Kerberos密钥

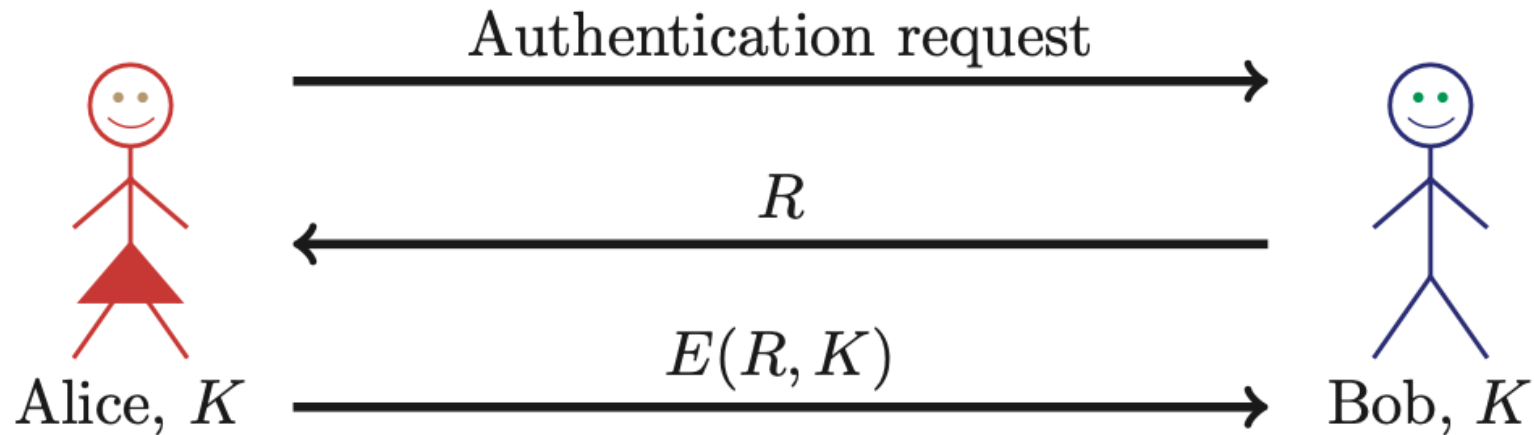
- 在 Kerberos 中, $K_A = h(\text{Alice 的密码})$
- 也可以生成随机的 K_A
 - 计算 $K_h = h(\text{Alice 的密码})$
 - 而 Alice 的电脑存储了 $E(K_A, K_h)$
- 那么, 当 Alice 更改密码时, K_A 无需更改。
 - 但是 $E(K_A, K_h)$ 必须存储在计算机上
- 这种替代方法经常被采用。
 - 但在 Kerberos 中并非如此 (追求无状态)



WEP

- WEP (Wired Equivalent Privacy)——有线等效加密
- WEP 是一种早期的**无线局域网 (Wi-Fi) 加密协议**，目标是**使无线局域网与有线局域网一样安全**。
- 根据Andrew S. Tanenbaum的说法：
 - **设计缺陷**：WEP设计非常脆弱，无法提供其名字所承诺的“有线等效”的安全性。
 - **脆弱性**：WEP使用RC4流密码的方式存在严重问题。特别是初始化向量长度太短（24位）。容易被破译。

WEP身份验证



- Bob 是**无线接入点**
- 密钥 K 由接入点和**所有用户共享**
 - 密钥 K 很少（如果有的话）会改变。
- WEP存在很多很多安全漏洞。

WEP问题

- WEP 使用 RC4 加密算法来保证机密性。
 - RC4 是一种相对较强的加密算法。
 - 但WEP引入了一个不易察觉的缺陷.....
 -使得密码分析攻击成为可能
- WEP 使用 **CRC** 校验“完整性”。
 - 应该使用 **MAC** 或 **HMAC**（或类似设备）。
 - CRC 用于错误检测，而非加密完整性。
 - **每个人** 应该知道这里**不应该**使用CRC校验.....

WEP完整性问题

- WEP 的“完整性”并不能提供任何加密完整性。
 - CRC是线性的，流密码（异或）也是线性的。
 - Trudy可以更改**密文 以及 CRC**，以便对 *明文进行校验和计算*。 仍然有效
 - 然后，特鲁迪所做的改变就没被发现。
 - 无需了解明文内容！
- CRC不提供加密完整性检查
 - CRC旨在**检测随机错误**
 - 无法检测到智能变化

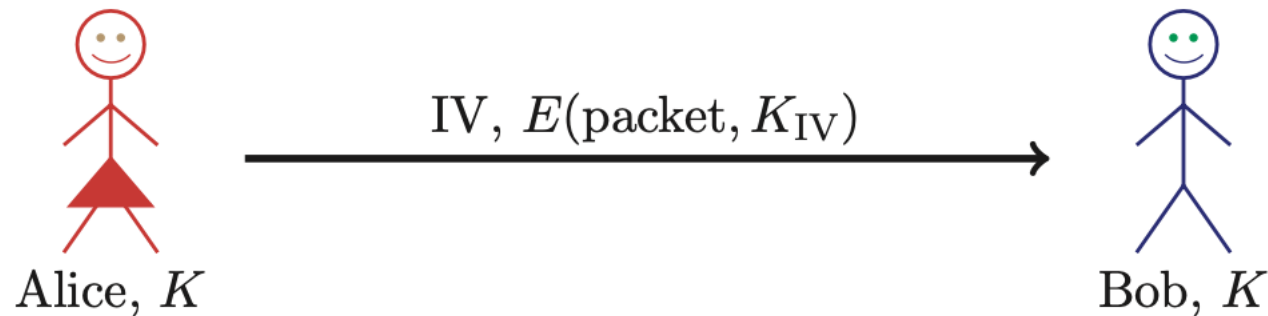
更多WEP完整性问题

- 假设 Trudy 知道目标 IP 地址
- 那么, Trudy 也知道用于加密 IP 地址的密钥流, 因为
$$C = \text{目标 IP 地址} \oplus \text{密钥流}$$
- 然后 Trudy 可以用 C' 替换
$$C' = \text{Trudy 的 IP 地址} \oplus \text{密钥流}$$
- 修改 CRC 校验值, 使其不再检测到错误。
 - 然后会发生什么?
- 寓意: 完整性缺失会带来大问题

WEP密钥

- 回想一下，WEP使用的是长期密钥K。
- RC4是一种流密码，因此每个数据包都必须使用不同的密钥进行加密。
 - 初始化向量（IV）随数据包发送
 - 明文发送，也就是说，IV不是秘密。
 - 注：IV与二战密码中的MI类似
- 数据包的实际RC4密钥为(IV, K)
 - 也就是说，IV被添加到长期密钥K之前。

WEP加密



- $K_{IV} = (IV, K)$
 - 也就是说，RC4密钥是K加上前面3字节的IV。
- 攻击者知道IV的存在。

WEP IV 问题

- WEP 使用 24 位（3 字节）初始化向量 (IV)。
 - 每个包裹都有自己的初始向量。
 - 密钥： IV 置于长期密钥 K 前面。
- 长期密钥 K 很少变化。
- 如果长期密钥和初始化向量相同， 则使用相同的密钥流。
 - 这太糟糕了， 真的太糟糕了！
 - 为什么？

WEP IV 问题

- 假设数据包大小为 1500 字节，链路速率为 11 Mbps。
- 假设初始化向量IV按顺序生成
 - 因为： $1500 \cdot 8 / (11 \cdot 10^6) \cdot 2^{24} = 18,000$ 秒，大约5小时的网络通信中就会出现重复
- 假设IV是随机生成的
 - 生日难题：初始化向量会在几秒钟内重复进行。
- 再次强调，重复使用IV（使用相同的K）是**不好的**。



24位初始化向量的
所有可能取值

另一种主动攻击

- 假设 Trudy 可以插入流量并观察相应的密文。
 - 然后她知道某种初始化向量的
 - 她可以解密任何使用该初始化向量的数据包。
- 如果攻击者多次这样做，她就可以解密大量IV的数据。
 - 记住，初始化向量是以明文形式发送的。
- 这种攻击可行吗？

密码分析攻击

- 使用 RC4 加密的 WEP 数据
 - 数据包密钥是IV，长期密钥为K
 - 3 字节IV被添加到K 的前面
 - 数据包密钥为 (IV, K)
- 记住：初始化向量是以明文形式发送的（并非秘密发送）。
 - 每个包裹都附有新的初始化向量。
 - 长期密钥K很少改变（可能永远不会改变）
- 所以攻击者总是知道初始化向量和密文。
 - 攻击者想找到钥匙K

密码分析攻击

- 密钥前附加3字节IV
- RC4 密钥字节用以下表示...
 - 字节: $k_0, k_1, k_2, k_3, k_4, k_5, \dots$
 - 其中初始化向量 $IV = (k_0, k_1, k_2)$, 攻击者知道这一点。
 - 攻击者想找到 $K = (k_3, k_4, k_5, \dots)$
- 只要有足够的IV, Trudy 就能轻松找到长期密钥K。
 - 无论密钥的长度如何
 - 假设攻击者知道第一个密钥流字节
 - 已知明文攻击 (每个数据包的第一个字节)
 - 用丢弃前 256 个密钥流字节来防止攻击

WEP结论

- 许多攻击都是实际可行的：初始化向量IV 重复攻击，RC4偏差攻击，已知明文攻击...
- 攻击手段已被用于恢复密钥和破坏真实的 WEP 流量。
- 如何预防这些攻击？
 - 不要使用 WEP 加密。
 - 不错的替代方案：WPA、WPA2 等。
- 如何改进 WEP 协议？
 - 限制 MAC 地址，不要广播 ID，.....
- WEP的安全缺陷来源于其加密机制本身，因此通过简单配置或者隐藏SSID来修复。这些只是增加一点使用门槛，但无法防止攻击。

WEP发展

- WEP
- WPA
- WPA2
- WPA3

WEP vs WPA vs WPA2 vs WPA3				
	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment

WEP发展

- WPA:
- **TKIP**: 用来在**不更换硬件**的情况下修补WEP的安全缺陷。
- 早期的单片机，轻量级嵌入式应用因为内存和CPU资源有限，所以只支持**RC4**，几乎不消耗内存。

WEP vs WPA vs WPA2 vs WPA3				
	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment

WEP发展

- WPA2:
- **AES-CCMP**: WPA2中使用的加密和完整性保护机制，基于AES算法。
- CCMP: Counter model+CBC+MAC
- 加密:Counter model
- 完整性:CBC-MAC

WEP vs WPA vs WPA2 vs WPA3				
	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment

WEP发展

- WPA3:
- **AES-GCMP**: WPA3中核心加密和完整性保护机制。
- GCMP: Galois/Counter model
- 加密: Counter model
- 完整性: 使用Galois Field运算

WEP vs WPA vs WPA2 vs WPA3				
	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment

支持硬件加速 适合高速 Wi-Fi (如 Wi-Fi 6)

GSM

- GSM: 早期手机网络的通信规则。
- 协议:
 - 手机如何接入网络
 - 如何打电话, 发短信
 - 如何进行身份认证和加密

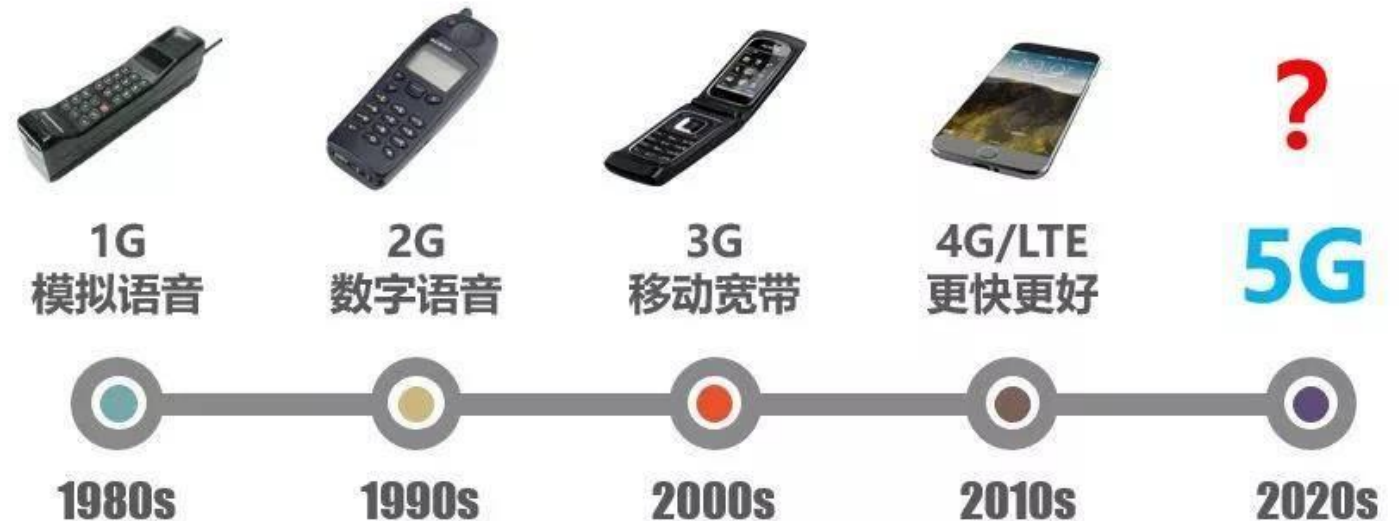


手机

- 第一代手机：大哥大（1G）
 - 砖块大小，模拟信号，标准少
 - 无加密，几乎**没有**安全保障
- 第二代：诺基亚/摩托罗拉（**GSM**）
 - 始于1982年，名为“集团”移动特辑”
 - 现在，全球移动通信系统
- 第三代：Nokia N95/iPhone 3G
 - 第三代伙伴关系项目（3GPP）

第四代：iPhone 6 支持4G LTE标准
使移动互联网全面普及。

第五代：iPhone/三星/华为，5G
超高速/低延迟，连接万物

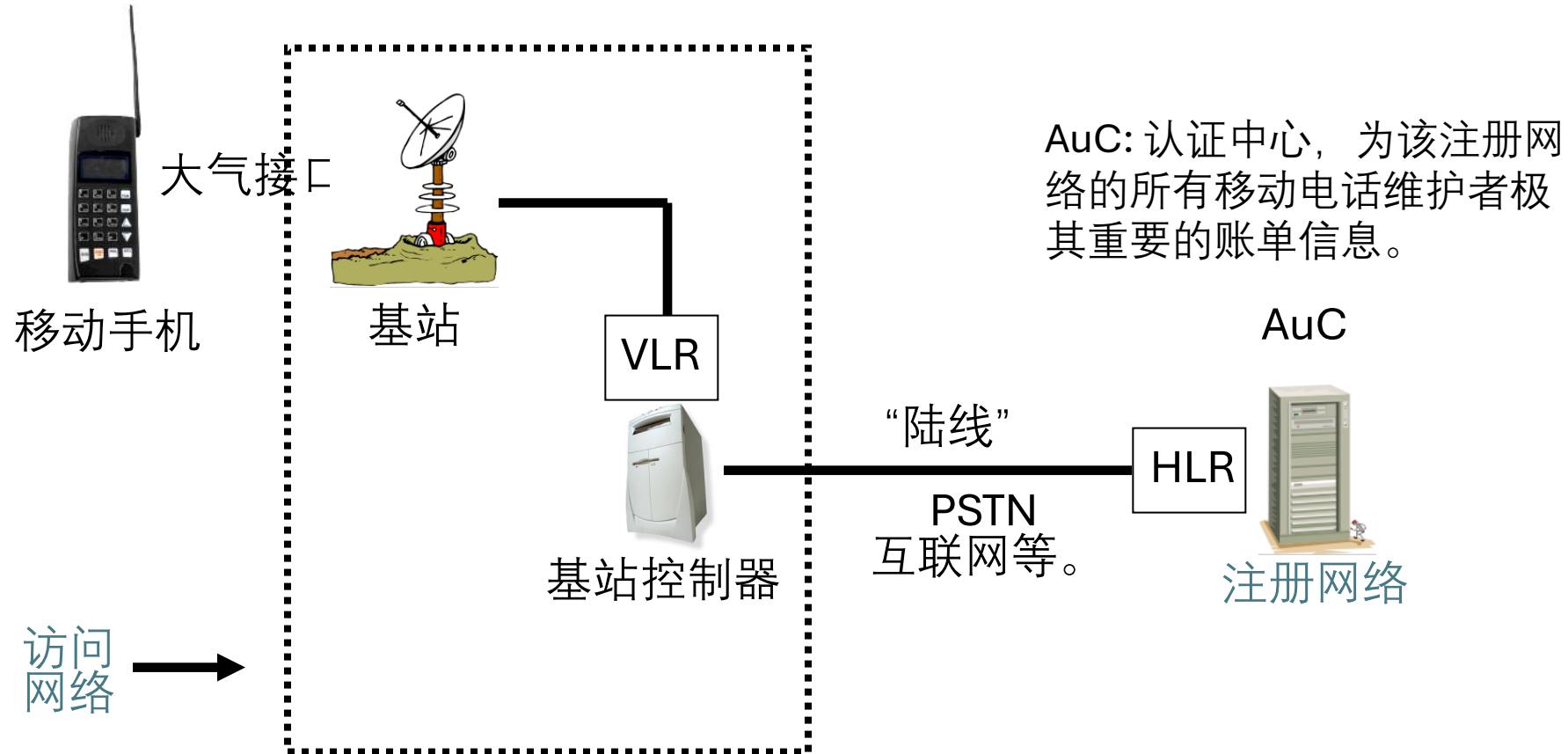


GSM

- 1G手机时代:
 - 早期的手机最大的安全性问题：克隆。
 - 电话呼叫时，手机使用明文广播他们的身份（用来确定账单）。
 - 攻击者可以**复制身份，进行克隆，从而转嫁账单**。
 - 2G发展→GSM协议（Global System for Mobile Communication）:
 - 加密（A5）
 - SIM卡
 - 挑战-响应认证
-  防止1G时代的克隆问题

GSM系统概述

- 大气接口：手机到基站的无线传输通道。
- 访问网络：包括多个基站和一个基站控制器，基站控制器包括一个访问位置登记（VLR）。
- PSTN：公共交换电话网络，普通的电话系统。也成为陆线，以和无线网络区别。
- 注册网络：手机注册的网络



GSM系统组件

- 手机
 - 包含SIM卡（用户识别模块）
- SIM卡是**安全模块**
 - IMSI（国际移动用户识别码）
 - 用户密钥：Ki（128 位）仅由移动电话和注册网络所知。
 - 防篡改（智能卡）
 - PIN码已激活（通常不使用）和SIM卡实现双因素认证^{SIM}



GSM系统组件

- **访问网络** ——移动设备当前所在网络
 - 基站——一个“小区”
 - 基站控制器——管理多个小区
 - VLR（访问位置寄存器） ——包含当前网络中所有访问移动设备的信息
- **注册网络** ——移动设备的“家”
 - HLR（归属位置寄存器） ——用于跟踪移动设备的最新位置
 - AuC（认证中心） ——拥有IMSI和Ki

GSM安全目标

- 主要设计目标
 - 让GSM手机像普通电话一样安全
 - 防止手机克隆
- 并非设计用于抵御主动攻击
 - 当时这似乎不可行（当时所需设备及其昂贵）。
 - 如今，此类攻击显然是可行的.....
- 设计师认为最大的威胁是
 - 不安全的计费账单。
 - 腐败问题
 - 其他低技术攻击

GSM安全功能

- 匿名性

- 截获的流量无法识别用户身份。
- 对电话公司来说并不那么重要

- 验证

- 正确计费的必要条件
- 对电话公司来说非常非常重要!

- 保密性

- 空中接口通话的保密性
- 对电话公司来说并不重要.....
-除了市场营销之外。

GSM: 匿名性

- IMSI 用于初步识别呼叫者
- 然后使用 TMSI (临时移动用户识别码) 。
 - TMSI 频繁变化
 - TMSI 在发送时会进行加密。
- 并非强有力的匿名形式
- 但在许多情况下可能很有用

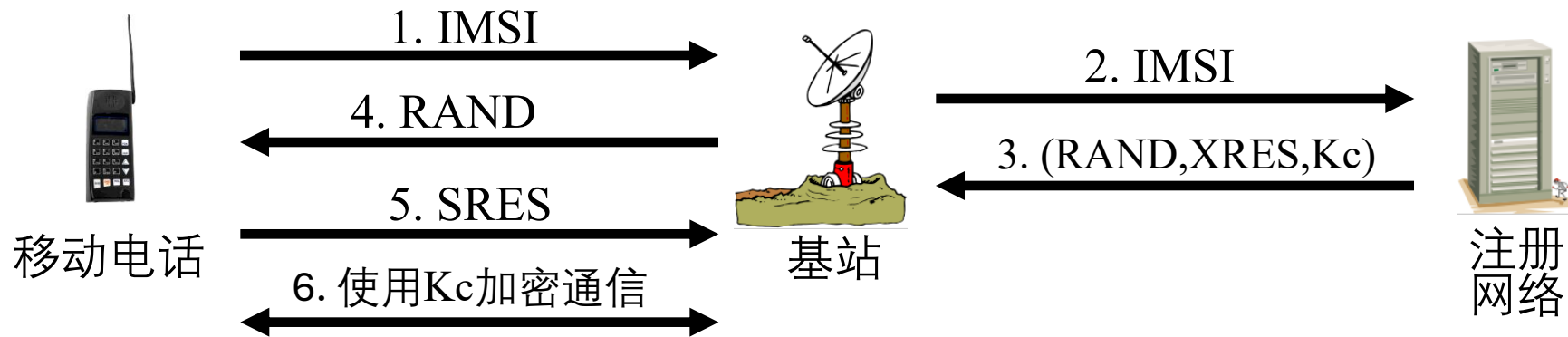
GSM: 身份验证

- 呼叫者已通过基站认证
- 身份验证**并非**双向的。
- 通过**质询-响应进行身份验证**
 - 家庭网络生成RAND, 并计算 $XRES = A3(RAND, K_i)$, 其中A3是哈希值。
 - 然后向基站发送 (RAND, XRES)
 - 基站发送**挑战RAND** 到移动电话
 - 移动电话的**响应**是 $SRES = A3(RAND, K_i)$
 - 基站验证 $SRES = XRES$
- **笔记:** K_i 从不离开家网络

GSM: 保密性

- 使用**流密码**加密的数据
- 错误率估计约为千分之一
 - 分组密码的错误率很高
- 加密密钥 K_c
 - 家庭网络计算 $K_c = A_8(RAND, K_i)$ ，其中 A_8 是哈希值。
 - 然后 K_c 发送到基站 ($RAND, XRES, K_c$)
 - 移动电话计算 $K_c = A_8(RAND, K_i)$ ，基站已经知道 K_c 。这样移动电话和基站建立加密会话的一个共享对称密钥。
 - 由 $A_5(K_c)$ 生成的
- **笔记：** K_i 从不离开家网络

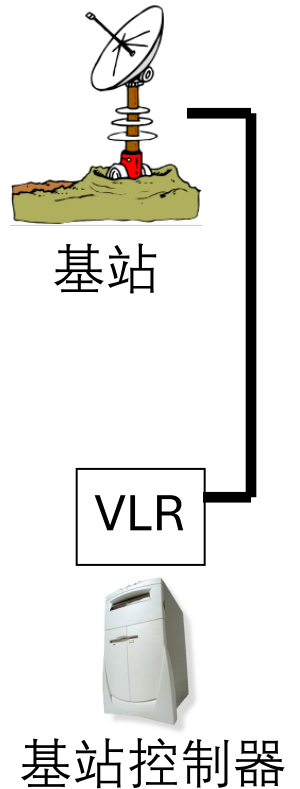
GSM安全



- SRES和Kc必须不相关。
 - 尽管两者都源自RAND和Ki
- 必须不能从已知的RAND/SRES对中推断出Ki (已知明文攻击)
- 必须无法从选定的RAND/SRES对中推断出Ki (选择明文攻击)
 - 攻击者只要拥有SIM卡, 就可以选择随机数。

GSM安全隐患 (1)

- A3/A8使用的哈希值为COMP128
 - 被 150,000 条选定的明文破解
 - 使用SIM卡, 可在2至10小时内获得Ki值
- 移动电话与基站之间有加密, 但基站与基站控制器之间**没有加密。**
 - 通常通过微波链路传输
- 加密算法A5/1
 - 仅需 2 秒已知明文即可破解



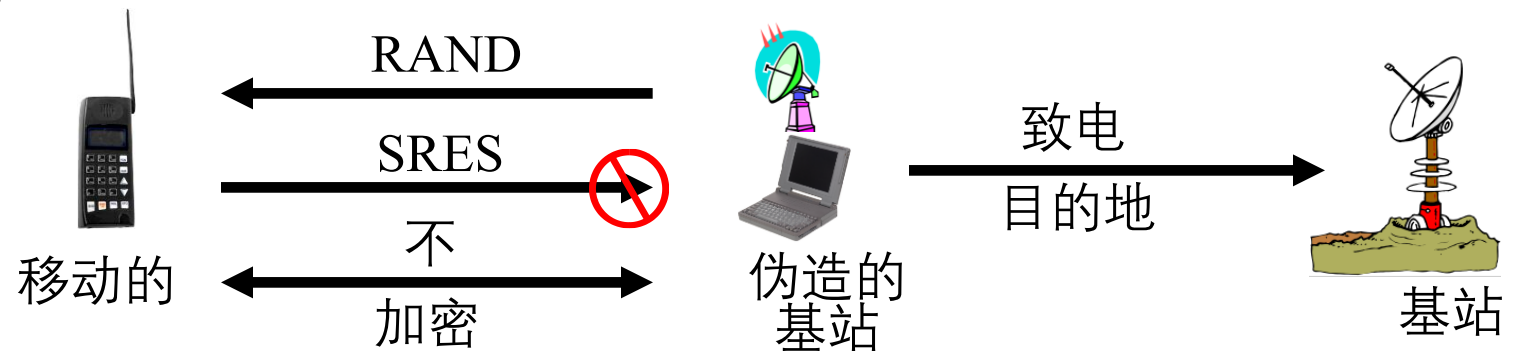
GSM安全隐患 (2)

- 对 SIM 卡的攻击
 - **光学故障感应** ——可能会用闪光灯攻击SIM卡以恢复Ki
 - **分区攻击** ——利用时间和功耗，仅使用 8 个自适应选择的“明文”即可恢复Ki。
- 攻击者只要掌握了SIM卡，就能在几秒钟内恢复Ki值。

GSM安全隐患 (3)

- 假基站利用了两个漏洞

1. 加密并非自动进行
2. 基站未通过认证。



□ 笔记: GSM账单竟然寄到了假基站!

GSM安全隐患 (4)

- 拒绝服务攻击是可能的
 - 干扰（无线网络中始终存在的问题）
- 可重放三重奏：（ RAND 、 XRES、 K_c ）
 - 永久有效的密钥K_c 。
 - 这里没有回放保护

GSM结论

- GSM是否实现了其目标？
 - 杜绝克隆？ **实际上，是的。**
 - 让空中接口像公共交换电话网络 (PSTN) 一样安全？ **或许可以.....**
- 但设计目标显然过于局限。
- GSM 安全漏洞——加密技术薄弱、SIM 卡问题、假基站、重放攻击等。
- PSTN 安全漏洞——窃听、主动攻击、被动攻击（例如，无绳电话）等。
- GSM在安全方面取得了（有限的）成功吗？

3GPP

- 基于GSM的3G安全（不）安全
- 3G修复了已知的GSM安全问题
 - 相互认证
 - 完整性保护信令（例如“开始加密”命令）
 - 密钥（加密/完整性密钥）不能重复使用
 - 三元组不能重打
 - 强加密算法（KASUMI）
 - 加密功能已扩展到基站控制器

GSM演进

代际	标准	认证方式	加密算法	关键安全机制	主要弱点	安全性
2G	GSM	✗ 单向认证	A5/1, A5/2	SIM 卡认证、TMSI	假基站、弱加密、无完整性保护	✗ 很弱
3G	UMTS	✓ 双向认证	KASUMI	AKA协议、完整性保护	部分算法老旧	⚠ 较安全
4G	LTE	✓ 双向认证	AES, SNOW 3G	EPS-AKA、IP层安全	降级攻击	✓ 安全
5G	5G	✓ 强双向认证	AES, ZUC	SUCI隐私保护、增强AKA	仍可能被降级	🚀 很强

Next week

- 软件和安全
 - 软件缺陷——缓冲区溢出等。
 - 恶意软件——病毒、蠕虫等。
 - 软件逆向工程
 - 数字版权管理
 - 操作系统和安全/NGSCB

Thank you.